



Invarune
by NimeshBuild

SECURITY CONTROLBOOK / RESEARCH EDITION

AI Agent & MCP Security

Evidence for agent security.

Source-linked controls for the systems that reason,
use tools, and act.

66

CONTROLS

132

ACCEPTANCE CHECKS

42

STATIC RULES

NSA + CISA / CSA / MITRE / NIST

OWASP / MCP / CIS / standards + research benchmarks

RESEARCH SNAPSHOT 19 SEPTEMBER 2026

github.com/nimeshbuilds/agent-mcp-security

NAVIGATION

Contents

Click a row or use the PDF bookmarks to move through the complete source-linked controlbook.

Reading guide and assurance labels	3
Source landscape	4
Security review workflow	5
Coverage, misses and validation - execution / identity	6
Coverage, misses and validation - prompts / data	7
Coverage, misses and validation - images / operations	8
Scan configuration and optional review	9
Human review and evidence-bound import	10
Controlled security analyst	11
Benchmarks and attack suites	12
Governance	15
Identity and authorization	18
MCP protocol and tools	23
Agent behavior and context	28
Execution and application security	32
Data and privacy	36
Supply chain	39
Operations and resilience	42
Security validation	45
42-rule static inventory	50
Full primary-source directory	53

01 / READING GUIDE

From code patterns to assurance

The Invarune catalog by NimeshBuild, with evidence requirements and a traceable source for every control.

Use this book to review agents, MCP clients and servers, gateways, tools, retrieval, memory, and the infrastructure that grants them authority. It is a synthesized engineering checklist, not a reproduction of every external framework or a certification claim.

FIND THE CONTROL YOU NEED

Governance	06 controls	15
Identity and authorization	09 controls	18
MCP protocol and tools	10 controls	23
Agent behavior and context	07 controls	28
Execution and application security	07 controls	32
Data and privacy	06 controls	36
Supply chain	06 controls	39
Operations and resilience	06 controls	42
Security validation	09 controls	45

Controlled security analyst: page 11

Static-rule index: page 50 / **Full source directory:** page 53

Read the labels carefully. A source link shows provenance or thematic alignment. It does not mean that every acceptance check is quoted from that source, or that a rule satisfies an entire external requirement. The applicability and limitations of each source appear in the directory.

02 / SOURCE LANDSCAPE

Different sources. Different jobs.

Combine guidance, control catalogs, protocol obligations, deployment baselines, and measured attack behavior.

NSA + CISA

GOVERNMENT GUIDANCE

Agent adoption, secure deployment, data protection, lifecycle practices, and incident readiness.

CSA

AI + CLOUD CONTROLS

AI Controls Matrix, MAESTRO threat modeling, cloud shared responsibility, and supplier evidence.

NIST

RISK + SECURE DEVELOPMENT

AI RMF, GenAI Profile, adversarial ML taxonomy, SSDF and its AI-specific profile.

MITRE ATLAS

THREAT KNOWLEDGE BASE

Attacker techniques and attack paths. Use to build scenarios; it is not an assurance score.

OWASP

RISK + VERIFICATION CATALOGS

Agentic and LLM risks, MCP guidance, and AI security verification requirements.

MCP

PROTOCOL SPECIFICATION

Version-sensitive transport, authorization, tool, sampling, elicitation, and trust requirements.

CIS

HARDENING BENCHMARKS

Agent/MCP companion guidance and configuration baselines for applicable server and deployment layers.

ISO / OpenSSF / SLSA

MANAGEMENT + SOFTWARE INTEGRITY

Governance context, project security practices, and build provenance. Applicability varies by artifact.

AIUC + research suites

ASSURANCE + EXPERIMENTS

Additional agent-control context and executable attacks under explicit harness assumptions.

This is a broad, curated landscape verified for this edition. No finite snapshot covers every publication or future benchmark. External catalogs retain their own scope, version, terms, and assessment procedures.

03 / VALIDATION METHOD

Make every decision reviewable

Keep deterministic signals, runtime evidence, human assessment, and LLM opinions separate.

1

Scope the system

Record agent/server identity, tools, model and gateway versions, MCP revision, data classes, deployment, and who can influence each input. Include downstream side effects and credentials.

2

Run the static scan

The CLI performs 42 selected checks. Keep findings, evidence, severity, confidence, remediation, exceptions, and coverage gaps. An absent pattern is not a passed control.

3

Test the effective boundary

Use isolated deployments, synthetic credentials, explicit canaries, and safe effect sinks. Verify identities, tenant boundaries, approvals, egress, cancellation, quotas, and audit records.

4

Measure attacks and useful work

Pin the benchmark, model, tools, settings, and attack budget. Report unauthorized actions and data leakage alongside benign task completion, false blocking, sample size, and repeated attempts.

5

Record a human disposition

For every applicable control, retain owner, scope, evidence, result, review date, and any time-limited exception. Use validated, failed, not applicable with rationale, or not validated.

Optional controlled security analyst

When enabled, every control receives an advisory review through deterministic evidence retrieval, bounded requests, strict schemas, and exact-quote checks. The LLM remains nondeterministic. Runtime and owner verification stay open; static findings and the severity gate remain intact. See page 5 for the review contract.

METHOD COVERAGE

What each layer can establish

Real catalog counts and explicit blind spots. Mapping is not accuracy, compliance, or percent secure.

Controls with static rule mappings		26
Controls without static rule mappings		40

Execution and data flow

DETERMINISTIC: Python AST checks with bounded local aliases/values; JavaScript/TypeScript tokens and balanced calls identify selected eval, shell, deserialization, SQL and template patterns.

OPTIONAL ANALYST: A model can explain a retrieved call path, question whether input is trusted and identify contextual concerns the pattern rules do not encode.

CAN MISS OR MISCLASSIFY: Cross-file flows, dynamic imports, wrappers, reflection, generated code, unsupported languages and runtime values can hide a risk. A dangerous API can also be intentional and correctly constrained.

VALIDATE ELSEWHERE: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

DETERMINISTIC: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

OPTIONAL ANALYST: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

CAN MISS OR MISCLASSIFY: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

VALIDATE ELSEWHERE: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

METHOD COVERAGE

What each layer can establish

Real catalog counts and explicit blind spots. Mapping is not accuracy, compliance, or percent secure.

Prompt injection, retrieval and memory

DETERMINISTIC: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

OPTIONAL ANALYST: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

CAN MISS OR MISCLASSIFY: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

VALIDATE ELSEWHERE: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

DETERMINISTIC: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

OPTIONAL ANALYST: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

CAN MISS OR MISCLASSIFY: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

VALIDATE ELSEWHERE: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

METHOD COVERAGE

What each layer can establish

Real catalog counts and explicit blind spots. Mapping is not accuracy, compliance, or percent secure.

Built images and supply chain

DETERMINISTIC: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

OPTIONAL ANALYST: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

CAN MISS OR MISCLASSIFY: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

VALIDATE ELSEWHERE: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.

Operations and control effectiveness

DETERMINISTIC: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

OPTIONAL ANALYST: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

CAN MISS OR MISCLASSIFY: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

VALIDATE ELSEWHERE: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

CONFIGURATION

Choose the evidence, then the limits

The default scan is offline and deterministic. Optional review and PDF dependencies are selected explicitly.

TARGET

Source directory, local Docker/Podman image reference, or Docker-save/OCI archive. No target program or container is started.

BOUNDS + EXCLUSIONS

Declare file/byte/entry/image limits and exclusions. Unsupported syntax, truncated evidence and exhausted budgets remain visible gaps.

DETERMINISTIC OUTPUT

HTML, Markdown, JSON and SARIF are generated without LLM credentials. --pdf adds an interactive PDF when the optional pdf extra is installed.

OPTIONAL ANALYST

Select an API/custom gateway configuration or the official Codex, Claude Code or Grok Build CLI. Review can be full-control or findings-only, with explicit call/time/evidence bounds.

USER DISPOSITIONS

--review-config applies explicit rule/control/check exceptions. --review-report imports edited report fields into a fresh scan. Neither is automatically loaded from the target.

EXIT + ASSURANCE

The findings threshold is a policy gate, not a security grade. Operational gaps and required human/runtime validation remain incomplete. Justified is distinct from pass.

HUMAN REVIEW

From a report to an auditable decision

Review fields carry evidence bindings. Edited reports cannot replay a target, command, gateway or model automatically.

SCAN

01

Choose source/image and configuration. Collect static evidence and a bound review workspace.

REVIEW

02

Inspect the finding or check. Run required human/runtime validation in the authorized environment.

RECORD

03

Choose a decision. Record reason, reviewer, reviewed-at date and a reference to supporting evidence.

SAVE

04

Save HTML/Markdown/JSON/SARIF review data or a compatible fillable PDF with current appearances.

IMPORT

05

Run a fresh explicit target scan with `--review-report`. Origin, source, catalog and item bindings are rechecked.

RESOLVE

06

Stale or invalid edits stay visible for re-review. Only valid, applicable decisions affect the result.

Decision semantics: justified/disabled require an accountable reviewer and reason; they are excluded from active denominators, never counted as passes. Notes do not waive findings. Runtime/human-validation decisions keep work outstanding. Coverage gaps cannot be waived. PDF canonical fields, widgets and appearance text must agree; ambiguous or flattened forms need JSON review instead.

03 / VALIDATION METHOD / CONTINUED

Controlled security analyst

Deterministic boundaries around nondeterministic expertise. Source review produces advice; it does not establish deployed security.

01 Route every unresolved control

Static rules provide partial evidence, so full mode queues all 66 controls and 132 acceptance checks, including controls with no findings. An empty pattern scan never closes a control.

02 Collect evidence deterministically

Read only unchanged files in the scan manifest. Check file hashes and path confinement, exclude credential files, redact excerpts, and select bounded context using fixed control terms and finding locations.

03 Run the bounded analyst

Use the configured model or custom JSON gateway. Fixed batches and call, size, and time budgets constrain review. Repository content is untrusted; no model-directed reads, local tools, or target execution occur.

04 Validate the response contract

Require known control/check IDs, allowed statuses, and exact evidence quotes for support, gaps, or proposed non-applicability. Derive file and line metadata from submitted excerpts. Reject malformed or fabricated output.

05 Keep gaps visible and auditable

Record every check, explanation, citation, verification step, and request receipt. Omitted checks and exhausted budgets remain unreviewed. The first failed batch stops further calls; static results are preserved.

Advisory outcomes

Code support / potential gap / runtime validation needed / human review needed / insufficient evidence / non-applicability proposed. Code support cannot complete manual or dynamic controls. Quote validation proves presence in an excerpt, not the model's interpretation.

Default review envelope

11 control batches of 6, within a 12-call cap, plus one finding-triage request. Evidence: at most 200 files / 2 MB; 240 excerpts / 120,000 characters; four excerpts per control. The 180-second scheduling budget is not a hard process deadline. Full mode sends source excerpts even with zero findings. Use --judge-mode findings for finding-only review.

04 / EXECUTABLE EVALUATION

Test behavior, not just code

Research benchmark results apply to a defined harness and threat model. None was executed to produce this handbook.

AgentDojo

[BENCH-AGENTDOJO / NeurIPS 2024; living repository](#)

Indirect prompt injection and legitimate task utility in tool workflows.

Use with care: Simulated suites and evolving API; adapt to production tools and policies. Not executed here.

[Open the primary source](#)

InjecAgent

[BENCH-INJECAGENT / 2024 research; living repository](#)

Malicious tool-result scenarios for tool-integrated agents.

Use with care: Fixed cases are not an adaptive attacker or production permission test. Not executed here.

[Open the primary source](#)

Agent Security Bench (ASB)

[BENCH-ASB / ICLR 2025; living repository](#)

Multiple agent scenarios and attack/defense evaluation methods.

Use with care: Match harness, agent, and tools; published scores do not transfer automatically. Not executed here.

[Open the primary source](#)

04 / EXECUTABLE EVALUATION

Test behavior, not just code

Research benchmark results apply to a defined harness and threat model. None was executed to produce this handbook.

MCPSecBench

[BENCH-MCPSECBENCH / 2025 research; living repository](#)

MCP security playground and attack scenarios across protocol surfaces.

Use with care: Environment/client-specific research workflows; not arbitrary-repository auditing or current-spec conformance. Not executed here.

[Open the primary source](#)

MCP Security Bench (MSB)

[BENCH-MSB / Paper v2; ICLR 2026; living repository](#)

Real MCP tool attacks across planning, invocation, and response handling with a security/utility trade-off metric.

Use with care: Distinct from MCPSecBench; selected tools, domains, agents, and code revisions bound results. Not executed here.

[Open the primary source](#)

MCP-SafetyBench

[BENCH-MCP-SAFETY / Paper v2; living repository](#)

Multi-turn, cross-server safety evaluation using real MCP servers in five domains and 20 attack types.

Use with care: Service state, harness assumptions, and task selection affect reproducibility; not protocol authorization certification. Not executed here.

[Open the primary source](#)

04 / EXECUTABLE EVALUATION

Test behavior, not just code

Research benchmark results apply to a defined harness and threat model. None was executed to produce this handbook.

AgentDyn

[BENCH-AGENTDYN / Paper v3; living repository](#)

Dynamic open-ended tasks and helpful third-party instructions expose over-blocking by injection defenses.

Use with care: Extends AgentDojo and inherits harness assumptions; avoid double-counting identical scenarios. Not executed here.

[Open the primary source](#)

AgentHarm

[BENCH-AGENTHARM / ICLR 2025; living Inspect Evals implementation](#)

Harmful multi-step user requests and jailbreaks with corresponding benign tasks.

Use with care: Different threat model from indirect injection. Grading can use LLMs; public subsets, scoring revisions, and safety/security-use license apply. Not executed here.

[Open the primary source](#)

BIPIA

[BENCH-BIPIA / 2023 initial paper; living repository](#)

Indirect prompt injection in external email, web, table, summarization, and code content.

Use with care: External-content robustness, not full agent/MCP transport security; some datasets require separate licensed acquisition. Not executed here.

[Open the primary source](#)

05 / CONTROL CATALOG

Governance

GOV-01 - GOV-02 / Check applicability, retain evidence, and resolve exceptions.

GOV-01

MANUAL VALIDATION

Inventory every agent, MCP server, tool, and model

- ☐ Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.
- ☐ Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-RMF](#) / [CSA-AICM](#) / [CSA-AISMM](#) / [CIS-AGENTS-2026](#) / [CIS-MCP-2026](#)

GOV-02

MANUAL VALIDATION

Model trust boundaries and attack paths

- ☐ Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.
- ☐ Identify who controls each input and the highest-impact action reachable if that input is malicious.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MITRE-ATLAS](#) / [NIST-AML](#) / [CSA-MAESTRO](#) / [MITRE-ATLAS-202609](#)

05 / CONTROL CATALOG

Governance

GOV-03 - GOV-04 / Check applicability, retain evidence, and resolve exceptions.

GOV-03

MANUAL VALIDATION

Define authorized use and accountable owners

- ☐ Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.
- ☐ Record impact, reversibility, approval requirements, and accepted residual risk before production use.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-RMF](#) / [JOINT-AGENTIC](#) / [CSA-AICM](#) / [CSA-SCOPING](#) / [CSA-AISMM](#) / [AIUC1-Q3-2026](#)

GOV-04

MANUAL VALIDATION

Maintain evidence and risk exceptions

- ☐ Give each control an owner, evidence link, validation date, result, and next review date.
- ☐ Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-GENAI](#) / [NIST-SSDF](#) / [CSA-AICM](#) / [CSA-AISMM](#) / [NIST-SSDF-AI](#)

05 / CONTROL CATALOG

Governance

GOV-05 - GOV-06 / Check applicability, retain evidence, and resolve exceptions.

GOV-05

MANUAL VALIDATION

Reassess changes in autonomy and integrations

- ☐ Review security impact when adding a model, tool, server, data source, skill, or broader permission.
- ☐ Require deployment evidence for the complete configured system; a model-only score is insufficient.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NCSC-SECURE-AI](#) / [CSA-AICM](#) / [CSA-SCOPING](#)

GOV-06

MANUAL VALIDATION

Assign shared security responsibilities across AI providers

- ☐ For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.
- ☐ Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [CSA-AICM](#) / [CSA-CCM](#)

05 / CONTROL CATALOG

Identity and authorization

AUTH-01 - AUTH-02 / Check applicability, retain evidence, and resolve exceptions.

AUTH-01

HYBRID VALIDATION

Authenticate protected operations on every request

- ☐ Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.
- ☐ Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI026, AI041 (partial)

Source context: [MCP-AUTH](#) / [CSA-AGENT-IAM](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C10](#)

AUTH-02

HYBRID VALIDATION

Authorize the exact action and target

- ☐ Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.
- ☐ Deny by default; test read-only callers against write tools and object identifiers owned by another user.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI027 (partial)

Source context: [JOINT-AGENTIC](#) / [MCP-TOOLS](#) / [CSA-AICM](#) / [CSA-AGENT-IAM](#) / [CSA-SCOPING](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C9](#) / [OWASP-AISVS-C10](#)

05 / CONTROL CATALOG

Identity and authorization

AUTH-03 - AUTH-04 / Check applicability, retain evidence, and resolve exceptions.

AUTH-03

HYBRID VALIDATION

Validate access-token cryptography and claims

- ☐ Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.
- ☐ Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI017 (partial)

Source context: [MCP-AUTH-SEC](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C10](#)

AUTH-04

HYBRID VALIDATION

Prevent token passthrough and confused deputy use

- ☐ Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.
- ☐ Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI028 (partial)

Source context: [MCP-AUTH](#) / [MCP-SECURITY](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C10](#)

05 / CONTROL CATALOG

Identity and authorization

AUTH-05 - AUTH-06 / Check applicability, retain evidence, and resolve exceptions.

AUTH-05

HYBRID VALIDATION

Constrain credential lifetime and exposure

- ☐ Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.
- ☐ Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI010, AI011, AI030, AI034 (partial)

Source context: [MCP-AUTH-SEC](#) / [JOINT-DEPLOY](#) / [CSA-AGENT-IAM](#) / [CIS-AGENTS-2026](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C9](#)

AUTH-06

HYBRID VALIDATION

Bind OAuth flows and validate redirects

- ☐ Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.
- ☐ Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI038 (partial)

Source context: [MCP-AUTH-SEC](#) / [MCP-AUTH](#)

05 / CONTROL CATALOG

Identity and authorization

AUTH-07 - AUTH-08 / Check applicability, retain evidence, and resolve exceptions.

AUTH-07

HYBRID VALIDATION

Secure OAuth discovery and registration

- ☐ Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.
- ☐ Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MCP-SECURITY](#)

AUTH-08

HYBRID VALIDATION

Bind delegation to identity, scope, and expiry

- ☐ Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.
- ☐ Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [OWASP-AGENT-CS](#) / [CSA-AGENT-IAM](#) / [NIST-AGENT-IDENTITY-DRAFT](#) / [CIS-AGENTS-2026](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C9](#)

05 / CONTROL CATALOG

Identity and authorization

AUTH-09 - AUTH-09 / Check applicability, retain evidence, and resolve exceptions.

AUTH-09

DYNAMIC VALIDATION

Manage agent identity enrollment and retirement

- ☐ Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.
- ☐ Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.**Static coverage:** No mapped rule; obtain review or runtime evidence.**Source context:** [CSA-AGENT-IAM](#) / [NIST-AGENT-IDENTITY-DRAFT](#)

ASSESSMENT RECORD

Use this space to record evidence for the control above. A source citation or a clean scan alone is not a validation result.

Owner / review date

Evidence / test run

Result / exception / next action

05 / CONTROL CATALOG

MCP protocol and tools

MCP-01 - MCP-02 / Check applicability, retain evidence, and resolve exceptions.

MCP-01

HYBRID VALIDATION

Validate transport exposure and origin

- ❑ For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.
- ❑ Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI006, AI007, AI008, AI029 (partial)

Source context: [MCP-HTTP](#) / [OWASP-AISVS-C10](#)

MCP-02

HYBRID VALIDATION

Validate tool arguments and results

- ❑ Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.
- ❑ Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MCP-TOOLS](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C9](#) / [OWASP-AISVS-C10](#)

05 / CONTROL CATALOG

MCP protocol and tools

MCP-03 - MCP-04 / Check applicability, retain evidence, and resolve exceptions.

MCP-03

HYBRID VALIDATION

Treat descriptions and annotations as untrusted

- ☐ Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.
- ☐ Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MCP-TOOLS](#) / [OWASP-MCP-CS](#) / [OWASP-AISVS-C10](#)

MCP-04

HYBRID VALIDATION

Detect tool substitution and metadata changes

- ☐ Bind tool approval to verified server identity and the reviewed tool definition or version.
- ☐ Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [OWASP-MCP10](#) / [OWASP-AISVS-C10](#)

05 / CONTROL CATALOG

MCP protocol and tools

MCP-05 - MCP-06 / Check applicability, retain evidence, and resolve exceptions.

MCP-05

DYNAMIC VALIDATION

Protect state handles and legacy sessions

- ☐ Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.
- ☐ For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: AI038 (partial)

Source context: [MCP-TOOLS](#) / [MCP-SECURITY](#)

MCP-06

DYNAMIC VALIDATION

Constrain sampling and returned model context

- ☐ Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.
- ☐ Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MCP-SAMPLING](#)

05 / CONTROL CATALOG

MCP protocol and tools

MCP-07 - MCP-08 / Check applicability, retain evidence, and resolve exceptions.

MCP-07

HYBRID VALIDATION

Secure elicitation and URL interactions

- ☐ Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.
- ☐ Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MCP-ELICITATION](#)

MCP-08

HYBRID VALIDATION

Enforce filesystem isolation independently of roots

- ☐ Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.
- ☐ Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI015 (partial)

Source context: [MCP-ROOTS](#)

05 / CONTROL CATALOG

MCP protocol and tools

MCP-09 - MCP-10 / Check applicability, retain evidence, and resolve exceptions.

MCP-09

HYBRID VALIDATION

Constrain local server launch and inherited environment

- ☐ Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.
- ☐ Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI018, AI031 (partial)

Source context: [MCP-SECURITY](#) / [OWASP-MCP-CS](#) / [OWASP-AISVS-C10](#)

MCP-10

DYNAMIC VALIDATION

Apply version-aware metadata, caching, and cancellation

- ☐ Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.
- ☐ Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MCP-TRANSPORTS](#) / [MCP-HTTP](#)

05 / CONTROL CATALOG

Agent behavior and context

AGT-01 - AGT-02 / Check applicability, retain evidence, and resolve exceptions.

AGT-01

HYBRID VALIDATION

Enforce action policy outside the model

- ☐ Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.
- ☐ Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI027, AI031 (partial)

Source context: [ASD-HARNESS](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C9](#) / [AIUC1-Q3-2026](#)

AGT-02

DYNAMIC VALIDATION

Bind approval to the action executed

- ☐ Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.
- ☐ Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: AI031 (partial)

Source context: [OWASP-AGENT-CS](#) / [CSA-SCOPING](#) / [OWASP-AISVS-C9](#)

05 / CONTROL CATALOG

Agent behavior and context

AGT-03 - AGT-04 / Check applicability, retain evidence, and resolve exceptions.

AGT-03

HYBRID VALIDATION

Separate untrusted content from authoritative instructions

- ☐ Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.
- ☐ Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI032 (partial)

Source context: [OWASP-LLM2026](#)

AGT-04

HYBRID VALIDATION

Protect retrieval and persistent memory

- ☐ Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.
- ☐ Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [OWASP-AGENTIC](#) / [CSA-MAESTRO](#) / [CIS-AGENTS-2026](#)

05 / CONTROL CATALOG

Agent behavior and context

AGT-05 - AGT-06 / Check applicability, retain evidence, and resolve exceptions.

AGT-05

DYNAMIC VALIDATION

Keep objectives and authority bounded across agents

- ☐ Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.
- ☐ Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [OWASP-AGENTIC](#) / [CSA-MAESTRO](#) / [OWASP-AISVS-C9](#)

AGT-06

HYBRID VALIDATION

Protect agent configuration and skills

- ☐ Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.
- ☐ Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [MITRE-ATLAS](#) / [NCSC-SECURE-AI](#) / [AIUC1-Q3-2026](#)

05 / CONTROL CATALOG

Agent behavior and context

AGT-07 - AGT-07 / Check applicability, retain evidence, and resolve exceptions.

AGT-07

DYNAMIC VALIDATION

Prevent sensitive context leaving through legitimate tools

- ☐ Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.
- ☐ Use canary data to test encoded leakage and combinations of otherwise permitted tools.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.**Static coverage:** No mapped rule; obtain review or runtime evidence.**Source context:** [OWASP-MCP-CS](#)

ASSESSMENT RECORD

Use this space to record evidence for the control above. A source citation or a clean scan alone is not a validation result.

Owner / review date

Evidence / test run

Result / exception / next action

05 / CONTROL CATALOG

Execution and application security

EXEC-01 - EXEC-02 / Check applicability, retain evidence, and resolve exceptions.

EXEC-01

HYBRID VALIDATION

Prevent shell and command injection

- ☐ Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.
- ☐ Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI002, AI003, AI012 (partial)

Source context: [OWASP-MCP10](#) / [OWASP-OUTPUT2025](#)

EXEC-02

HYBRID VALIDATION

Constrain generated-code execution

- ☐ Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.
- ☐ Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI001, AI013 (partial)

Source context: [OWASP-AGENT-CS](#) / [OWASP-AISVS-C9](#) / [AIUC1-Q3-2026](#)

05 / CONTROL CATALOG

Execution and application security

EXEC-03 - EXEC-04 / Check applicability, retain evidence, and resolve exceptions.

EXEC-03

HYBRID VALIDATION

Parameterize database and query operations

- ☐ Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.
- ☐ Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI036 (partial)

Source context: [OWASP-OUTPUT2025](#)

EXEC-04

HYBRID VALIDATION

Constrain file and archive access

- ☐ Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.
- ☐ Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI015, AI016, AI037 (partial)

Source context: [MCP-ROOTS](#) / [JOINT-DEPLOY](#)

05 / CONTROL CATALOG

Execution and application security

EXEC-05 - EXEC-06 / Check applicability, retain evidence, and resolve exceptions.

EXEC-05

HYBRID VALIDATION

Prevent SSRF and unsafe network destinations

- ☐ Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.
- ☐ Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI014 (partial)

Source context: [MCP-SECURITY](#)

EXEC-06

HYBRID VALIDATION

Reject unsafe parsing and deserialization

- ☐ Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.
- ☐ Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI004, AI005, AI035 (partial)

Source context: [NIST-SSDF](#)

05 / CONTROL CATALOG

Execution and application security

EXEC-07 - EXEC-07 / Check applicability, retain evidence, and resolve exceptions.

EXEC-07

HYBRID VALIDATION

Render model and tool output safely

- ☐ Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.
- ☐ Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.**Static coverage:** AI039, AI040 (partial)**Source context:** [OWASP-OUTPUT2025](#)

ASSESSMENT RECORD

Use this space to record evidence for the control above. A source citation or a clean scan alone is not a validation result.

Owner / review date

Evidence / test run

Result / exception / next action

05 / CONTROL CATALOG

Data and privacy

DATA-01 - DATA-02 / Check applicability, retain evidence, and resolve exceptions.

DATA-01

STATIC VALIDATION

Detect and remove embedded credentials

- ☐ Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.
- ☐ Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

Evidence: Code/configuration location, applicable version, and reviewer disposition.

Static coverage: AI010, AI011, AI030, AI034 (partial)

Source context: [JOINT-DEPLOY](#) / [AIUC1-Q3-2026](#)

DATA-02

MANUAL VALIDATION

Minimize data sent to models and gateways

- ☐ Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.
- ☐ Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-GENAI](#) / [CSA-AICM](#) / [CIS-AGENTS-2026](#) / [AIUC1-Q3-2026](#)

05 / CONTROL CATALOG

Data and privacy

DATA-03 - DATA-04 / Check applicability, retain evidence, and resolve exceptions.

DATA-03

HYBRID VALIDATION

Protect logs, traces, and error responses

- ☐ Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.
- ☐ Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI009, AI033 (partial)

Source context: [OWASP-MCP10](#) / [CIS-AGENTS-2026](#) / [CIS-MCP-2026](#) / [AIUC1-Q3-2026](#)

DATA-04

MANUAL VALIDATION

Track provenance and integrity of AI data

- ☐ Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.
- ☐ Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NSA-DATA](#) / [CSA-AICM](#) / [NIST-SSDF-AI](#)

05 / CONTROL CATALOG

Data and privacy

DATA-05 - DATA-06 / Check applicability, retain evidence, and resolve exceptions.

DATA-05

DYNAMIC VALIDATION

Enforce retention and deletion across copies

- ☐ Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.
- ☐ Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-GENAI](#) / [CIS-AGENTS-2026](#)

DATA-06

HYBRID VALIDATION

Protect stored data and keys

- ☐ Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.
- ☐ Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NSA-DATA](#) / [JOINT-DEPLOY](#) / [CSA-CCM](#) / [CIS-AGENTS-2026](#)

05 / CONTROL CATALOG

Supply chain

SUP-01 - SUP-02 / Check applicability, retain evidence, and resolve exceptions.

SUP-01

STATIC VALIDATION

Pin and inventory executable dependencies

- ☐ Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.
- ☐ Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

Evidence: Code/configuration location, applicable version, and reviewer disposition.

Static coverage: AI018, AI024, AI025 (partial)

Source context: [NIST-SSDF](#) / [NIST-SSDF-AI](#) / [AIUC1-Q3-2026](#)

SUP-02

MANUAL VALIDATION

Check vulnerability and maintenance exposure

- ☐ Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.
- ☐ Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NCSC-SECURE-AI](#) / [CSA-AISMM](#) / [CIS-MCP-2026](#) / [OPENSSF-BASELINE-202608](#)

05 / CONTROL CATALOG

Supply chain

SUP-03 - SUP-04 / Check applicability, retain evidence, and resolve exceptions.

SUP-03

MANUAL VALIDATION

Verify artifact identity and provenance

- ☐ Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.
- ☐ Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: AI019, AI024, AI035 (partial)

Source context: NSA-DATA / NIST-SSDF / CSA-AICM / CSA-MAESTRO / NIST-SSDF-AI / OWASP-AISVS-C10 / SLSA-12 / OPENSSEF-MODEL-SIGNING

SUP-04

HYBRID VALIDATION

Protect build, release, and configuration changes

- ☐ Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.
- ☐ Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI020 (partial)

Source context: NIST-SSDF / NIST-SSDF-AI / CIS-MCP-2026 / OPENSSEF-BASELINE-202608 / SLSA-12

05 / CONTROL CATALOG

Supply chain

SUP-05 - SUP-06 / Check applicability, retain evidence, and resolve exceptions.

SUP-05

HYBRID VALIDATION

Harden runtime isolation and deployment defaults

- ☐ Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.
- ☐ Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: AI021, AI022, AI023, AI031, AI042 (partial)

Source context: [JOINT-DEPLOY](#) / [CSA-CCM](#) / [CSA-MAESTRO](#)

SUP-06

DYNAMIC VALIDATION

Separate and protect model development environments

- ☐ When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.
- ☐ Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-SSDF-AI](#)

05 / CONTROL CATALOG

Operations and resilience

OPS-01 - OPS-02 / Check applicability, retain evidence, and resolve exceptions.

OPS-01

HYBRID VALIDATION

Produce attributable audit events

- ☐ Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.
- ☐ Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [OWASP-MCP10](#) / [CSA-CCM](#) / [CSA-AGENT-IAM](#) / [CIS-AGENTS-2026](#) / [CIS-MCP-2026](#) / [OWASP-AISVS-C9](#)

OPS-02

HYBRID VALIDATION

Bound work, spending, and concurrency

- ☐ Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.
- ☐ Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

Evidence: Source/configuration trace plus negative-test result from the effective deployment.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [ASD-HARNESS](#) / [CSA-SCOPING](#) / [OWASP-AISVS-C9](#) / [OWASP-AISVS-C10](#)

05 / CONTROL CATALOG

Operations and resilience

OPS-03 - OPS-04 / Check applicability, retain evidence, and resolve exceptions.

OPS-03

DYNAMIC VALIDATION

Make cancellation and shutdown effective

- ☐ Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.
- ☐ Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [JOINT-AGENTIC](#) / [CSA-AGENT-IAM](#) / [OWASP-AISVS-C9](#)

OPS-04

DYNAMIC VALIDATION

Fail safely and prevent duplicate side effects

- ☐ Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.
- ☐ Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [ASD-HARNESS](#)

05 / CONTROL CATALOG

Operations and resilience

OPS-05 - OPS-06 / Check applicability, retain evidence, and resolve exceptions.

OPS-05**DYNAMIC VALIDATION**

Monitor behavior and support rollback

- ☐ Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.
- ☐ Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NCSC-SECURE-AI](#) / [CSA-CCM](#) / [CSA-AISMM](#)

OPS-06**MANUAL VALIDATION**

Practice incident response and disclosure

- ☐ Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.
- ☐ Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

Evidence: Named owner, approved scope, evidence record, review date, and exceptions.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [CISA-JCDC](#) / [CSA-AICM](#) / [CSA-CCM](#) / [CSA-AISMM](#) / [OPENSSF-BASELINE-202608](#)

05 / CONTROL CATALOG

Security validation

TEST-01 - TEST-02 / Check applicability, retain evidence, and resolve exceptions.

TEST-01

DYNAMIC VALIDATION

Measure prompt-injection security and useful task completion

- ☐ Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.
- ☐ Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [BENCH-AGENTDOJO](#) / [BENCH-INJECAGENT](#) / [MITRE-ATLAS-202609](#)

TEST-02

DYNAMIC VALIDATION

Test adaptively and repeat scenarios

- ☐ Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.
- ☐ Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-HIJACK-EVAL](#) / [MITRE-ATLAS-202609](#)

05 / CONTROL CATALOG

Security validation

TEST-03 - TEST-04 / Check applicability, retain evidence, and resolve exceptions.

TEST-03

DYNAMIC VALIDATION

Exercise MCP authentication and protocol abuse

- ☐ In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.
- ☐ Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [BENCH-MCPSECBENCH](#) / [MCP-AUTH](#) / [CIS-MCP-2026](#)

TEST-04

DYNAMIC VALIDATION

Verify cross-tenant and cross-agent isolation

- ☐ Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.
- ☐ Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [BENCH-ASB](#)

05 / CONTROL CATALOG

Security validation

TEST-05 - TEST-06 / Check applicability, retain evidence, and resolve exceptions.

TEST-05

DYNAMIC VALIDATION

Test approval, policy, and sandbox bypass

- ☐ Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.
- ☐ Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [OWASP-AGENT-CS](#) / [CIS-MCP-2026](#)

TEST-06

DYNAMIC VALIDATION

Verify conventional application security

- ☐ Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.
- ☐ Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-SSDF](#) / [OWASP-OUTPUT2025](#) / [NIST-SSDF-AI](#) / [CIS-MCP-2026](#) / [AIUC1-Q3-2026](#)

05 / CONTROL CATALOG

Security validation

TEST-07 - TEST-08 / Check applicability, retain evidence, and resolve exceptions.

TEST-07

DYNAMIC VALIDATION

Validate resource exhaustion and observability

- ❑ Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.
- ❑ Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [ASD-HARNESS](#)

TEST-08

DYNAMIC VALIDATION

Evaluate the optional security judge itself

- ❑ Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.
- ❑ Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [NIST-HIJACK-EVAL](#) / [NIST-GENAI](#)

05 / CONTROL CATALOG

Security validation

TEST-09 - TEST-09 / Check applicability, retain evidence, and resolve exceptions.

TEST-09

DYNAMIC VALIDATION

Evaluate model-layer attacks for hosted or customized models

- ☐ Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.
- ☐ Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

Evidence: Pinned scenario, expected policy, observed effects, and repeatable test results.

Static coverage: No mapped rule; obtain review or runtime evidence.

Source context: [CSA-MAESTRO](#) / [NIST-SSDF-AI](#)

ASSESSMENT RECORD

Use this space to record evidence for the control above. A source citation or a clean scan alone is not a validation result.

Owner / review date

Evidence / test run

Result / exception / next action

06 / AUTOMATION INDEX

What the scanner can flag

All rules are static signals. Confidence and context determine the next investigation step; no rule proves full control effectiveness.

RULE	SEVERITY	RISK PATTERN
AI001	HIGH	Dynamic Python code execution
AI002	HIGH	Dynamic command executed through a shell
AI003	HIGH	Dynamic os shell command
AI004	HIGH	Unsafe YAML object construction
AI005	HIGH	Executable deserialization requires trusted inputs
AI006	HIGH	TLS certificate verification disabled
AI007	MEDIUM	Wildcard cross-origin access
AI008	LOW	Service binds to all network interfaces
AI009	MEDIUM	Application debug mode enabled
AI010	HIGH	Credential-like literal in source or configuration
AI011	CRITICAL	Private key material in repository
AI012	HIGH	Dynamic JavaScript shell execution
AI013	HIGH	Dynamic JavaScript code execution
AI014	MEDIUM	Externally influenced outbound request

The machine-readable catalog maps these rules to selected controls. A rule match requires investigation. A suppressed finding remains visible as an accepted exception; an unmapped or untested control remains unvalidated.

06 / AUTOMATION INDEX

What the scanner can flag

All rules are static signals. Confidence and context determine the next investigation step; no rule proves full control effectiveness.

RULE	SEVERITY	RISK PATTERN
AI015	MEDIUM	Externally influenced filesystem path
AI016	MEDIUM	Race-prone temporary filename creation
AI017	HIGH	JWT verification explicitly bypassed
AI018	MEDIUM	MCP package runner resolves an unpinned artifact
AI019	HIGH	Remote download piped directly to a shell
AI020	MEDIUM	GitHub Action reference is not pinned to a commit
AI021	MEDIUM	Container explicitly runs as root
AI022	HIGH	Privileged container or privilege escalation enabled
AI023	HIGH	Container runtime socket exposed
AI024	LOW	Container image is not digest pinned
AI025	LOW	Direct dependency is not exactly pinned
AI026	HIGH	Authentication explicitly disabled
AI027	HIGH	Wildcard tool or permission authorization
AI028	HIGH	MCP token passthrough enabled

The machine-readable catalog maps these rules to selected controls. A rule match requires investigation. A suppressed finding remains visible as an accepted exception; an unmapped or untested control remains unvalidated.

06 / AUTOMATION INDEX

What the scanner can flag

All rules are static signals. Confidence and context determine the next investigation step; no rule proves full control effectiveness.

RULE	SEVERITY	RISK PATTERN
AI029	HIGH	Remote MCP URL uses plaintext HTTP
AI030	MEDIUM	Browser-side API credential access explicitly enabled
AI031	HIGH	Agent approval or sandbox safeguard explicitly bypassed
AI032	MEDIUM	External data inserted into privileged LLM instructions
AI033	MEDIUM	Potential secret included in logging call
AI034	HIGH	Credential-like value embedded in URL query
AI035	HIGH	Unsafe model checkpoint deserialization
AI036	HIGH	SQL query constructed with interpolation
AI037	MEDIUM	Archive extraction without an explicit safe filter
AI038	MEDIUM	Cryptographically weak randomness used for a security value
AI039	HIGH	Server-Side Template rendered from a dynamic template
AI040	MEDIUM	Unsafe HTML rendering boundary
AI041	HIGH	MCP inspector authorization explicitly disabled
AI042	HIGH	Container uses host namespaces

The machine-readable catalog maps these rules to selected controls. A rule match requires investigation. A suppressed finding remains visible as an accepted exception; an unmapped or untested control remains unvalidated.

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

JOINT-AGENTIC

Careful adoption of agentic AI services

ASD ACSC, CISA, NSA, CCCS, NCSC-NZ, NCSC-UK / Government guidance / Joint guidance / 2026-05-01

Agent privileges, identity, trust boundaries, autonomy, oversight, supply chain and accountable operation. **Limit:** ASD publication date; NSA announced it on April 30. Recommendations require system-specific implementation and evidence; this is not an executable benchmark.

www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-of-a...

NSA-AGENTIC

NSA announcement: Careful Adoption of Agentic AI Services

NSA / Government announcement / Joint guidance release / 2026-04-30

Confirms NSA participation, publication timing and joint authorship of agentic AI guidance. **Limit:** Announcement supports provenance; use the complete joint guidance for substantive control interpretation.

www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4475134/nsa-joins-th...

CISA-AGENTIC

CISA and Partners Release Guidance on Adopting Agentic AI Services

CISA / Government announcement / Official CISA bulletin / 2026-05-01

Confirms CISA participation and recommendations to bound autonomy and strengthen identity and oversight. **Limit:** Official bulletin hosted by GovDelivery. This is a release notice, not a separately scored framework.

content.govdelivery.com/accounts/USDHSCISA/bulletins/41544ff

ASD-HARNESS

Agentic AI harnesses: The layer above the model

ASD ACSC / Government guidance / Published guidance / 2026-09-11

Security responsibilities of orchestration, context, tool execution, memory, permissions and operational controls. **Limit:** ASD publication; do not attribute joint authorship to NSA or CISA. A secure model alone does not establish harness security.

www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agentic-ai-harnesses

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

JOINT-DEPLOY

Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems

NSA, CISA and international partners; ASD host / Government guidance / 1.0 / 2024-04-16

Infrastructure hardening, deployment controls, data protection, monitoring and secure AI operation. **Limit:** ASD page date. Focuses on operating externally developed AI, especially on-premises or private cloud; adapt infrastructure checks to hosted API usage.

www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-systems-...

NSA-DATA

AI Data Security: Best Practices for Securing Data Used to Train & Operate AI Systems (NSA announcement)

NSA, CISA, FBI and international partners / Government guidance announcement / Joint Cybersecurity Information Sheet / 2025-05-22

Data provenance, integrity, protection and lifecycle changes affecting training and operational data. **Limit:** The linked announcement points to the full information sheet. Local source review cannot establish provider practices or retrieval-corpus integrity.

www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc-re...

NCSC-SECURE-AI

Guidelines for secure AI system development

NCSC-UK, CISA and international partners / Government guidance / 1.0 / 2023-11-27

Secure design, development, deployment, operation and maintenance across the AI lifecycle. **Limit:** Lifecycle guidance requires implementation evidence; it does not prescribe an agent/MCP scanner or certify code.

www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development

CISA-JCDC

JCDC AI Cybersecurity Collaboration Playbook and Fact Sheet (release notice)

CISA / Government operational guidance / 2025 release / 2025-01-14

Incident collaboration, voluntary sharing processes and coordinated AI cybersecurity response. **Limit:** Operational playbook, not a source-code scanning standard or a mandate to disclose all findings.

www.cisa.gov/news-events/alerts/2025/01/14/cisa-releases-jcdc-ai-cybersecurity-collaboration-pla...

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

NIST-RMF

Artificial Intelligence Risk Management Framework (AI RMF 1.0)

NIST / Risk-management framework / AI 100-1; 1.0 / 2023-01-26

Risk ownership, system context, measurement and risk treatment. **Limit:** Voluntary framework, not a universal technical pass/fail checklist; project mappings select security-relevant practices.

www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10

NIST-RMF-PROGRAM

AI Risk Management Framework: program status

NIST / Program reference / Living page / Living page

Current program and revision information for AI RMF. **Limit:** A changing program page is not a released replacement for the cited AI RMF 1.0 publication.

www.nist.gov/itl/ai-risk-management-framework

NIST-GENAI

Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile

NIST / Risk-management profile / AI 600-1 / 2024-07

GenAI information security, privacy, data, evaluation and human interaction risks. **Limit:** Broader than agent/MCP security; selected mappings do not cover the whole profile. NIST records public release on July 26, 2024.

nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

NIST-RMF-RESOURCES

AI Risk Management Framework resources

NIST / Program reference / Living page / Living page

Publication context and release-date provenance for AI RMF resources and the GenAI Profile. **Limit:** Reference index, not a separate control framework; link to each actual publication when interpreting its requirements.

www.nist.gov/itl/ai-risk-management-framework/ai-risk-management-framework-resources

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

NIST-AML

Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations

NIST / Threat taxonomy / AI 100-2e2025 / 2025-03-24

Attacker capabilities, goals and attack classes including poisoning, privacy and prompt injection. **Limit:** Taxonomy is not conformance testing. The official record has a June 3, 2025 potential-updates note; check it before relying on precise identifiers.

csrc.nist.gov/pubs/ai/100/2/e2025/final

NIST-SSDF

Secure Software Development Framework (SSDF) Version 1.1

NIST / Secure-development framework / SP 800-218; 1.1 / 2022-02-03

Secure engineering, software integrity, vulnerability response and release lifecycle practices. **Limit:** Referenced for engineering context; this catalog is not an exhaustive SSDF compliance crosswalk.

csrc.nist.gov/pubs/sp/800/218/final

NIST-HIJACK-EVAL

Technical Blog: Strengthening AI Agent Hijacking Evaluations

NIST / Evaluation research / Technical blog / 2025-01-17

Adaptive attacks, repeated attempts and scenario-specific evaluation of agent hijacking. **Limit:** Research methodology does not establish production assurance or a certification; report the tested harness and attack budget.

www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluations

MITRE-ATLAS

ATLAS tactics, techniques, mitigations and case-study data

MITRE / Threat knowledge base / Living official repository / Living repository

Threat modeling, adversarial AI attack paths and security-test scenario design. **Limit:** Pin a content release and commit for exact IDs. Content and schema versions differ; this scanner does not calculate an ATLAS security score.

github.com/mitre-atlas/atlas-data

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

OWASP-AGENTIC

OWASP Top 10 for Agentic Applications for 2026

OWASP GenAI Security Project / Threat prioritization / 2026 edition / 2025-12-09

Agent goals, tool use, identity, memory, code execution, communication and cascading failures. **Limit:** A prioritized risk list, not an executable benchmark. Date follows the page display; machine metadata uses the following UTC day.

genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

OWASP-LLM2026

OWASP GenAI LLM Top 10 2026

OWASP GenAI Security Project / Threat prioritization / 2026 edition / 2026-08-03

Security risks of LLM-powered applications and their connected data and execution paths. **Limit:** Do not silently transfer category numbering from the 2025 edition. Date follows the displayed page rather than next-day UTC metadata.

genai.owasp.org/resource/owasp-genai-llm-top-10-2026/

OWASP-MCP10

OWASP MCP Top 10

OWASP / Threat prioritization / Living page; MCP01:2025-MCP10:2025 labels / Living page

MCP credentials, privilege scope, tool poisoning, supply chain, injection, audit and unapproved servers. **Limit:** Roadmap still describes beta/pilot even though the page also labels the project production. Treat maturity as mixed; it is not protocol conformance or benchmark completion.

owasp.org/projects/mcp-top-10

OWASP-MCP-CS

MCP Security Cheat Sheet

OWASP Cheat Sheet Series / Implementation guidance / Living document / Living document

Practical defenses for MCP identity, tools, data boundaries, operations and exposure. **Limit:** Reconcile version-sensitive recommendations against the actual deployed MCP revision; it is secondary to normative protocol requirements.

cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

OWASP-AGENT-CS

AI Agent Security Cheat Sheet

OWASP Cheat Sheet Series / Implementation guidance / Living document / Living document

Agent policies, isolation, context, tools and operational security testing. **Limit:** General implementation guidance requires architecture-specific interpretation and runtime evidence.

cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

OWASP-OUTPUT2025

LLM05:2025 Improper Output Handling

OWASP GenAI Security Project / Threat category / LLM05:2025 / 2025 edition

Validate and encode model output before it reaches interpreters, commands, queries or presentation sinks. **Limit:** Explicit historical category; its identifier must not be described as the 2026 numbering.

genai.owasp.org/llmrisk/llm052025-improper-output-handling/

OWASP-ACS

Agent Control Standard (ACS)

OWASP GenAI Security Project / Emerging control architecture / Resource publication / 2026-09-01

Runtime policy hooks and enforcement architecture for agent systems. **Limit:** Included as emerging architecture context; this scanner does not implement or claim conformance to ACS.

genai.owasp.org/resource/agent-control-standard-acs/

OWASP-CROSSWALK

GenAI Security Industry Framework Crosswalk

OWASP GenAI Security Project / Framework crosswalk / Resource publication / 2026-09-01

Comparison context across AI security guidance and frameworks. **Limit:** Project mappings are independently scoped. Do not infer exhaustive adoption of this third-party crosswalk.

genai.owasp.org/resource/genai-security-industry-framework-crosswalk/

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

MCP-SPEC

Model Context Protocol specification

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Reference revision for client/server protocol and conditional interoperability requirements. **Limit:** Record the deployed revision. Versioned web pages can receive edits; pin upstream source for formal audit evidence.

modelcontextprotocol.io/specification/2026-07-28

MCP-AUTH

MCP: Authorization

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

HTTP authorization, protected-resource discovery, audience restrictions and OAuth responsibilities. **Limit:** HTTP authorization is optional in the protocol; protected applications still need suitable controls. Stdio uses a different credential model.

modelcontextprotocol.io/specification/2026-07-28/basic/authorization

MCP-AUTH-SEC

MCP: Authorization Security Considerations

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Token validation, PKCE, issuer binding, redirects and authorization threat defenses. **Limit:** Requirements are conditional on roles and deployed protocol version; decoding a token alone does not validate it.

modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations

MCP-TRANSPORTS

MCP: Transport overview

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Transport selection, request metadata and compatibility across protocol revisions. **Limit:** The 2026-07-28 core differs from older session and initialize-handshake designs; do not label older code a violation without checking its advertised version.

modelcontextprotocol.io/specification/2026-07-28/basic/transports

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

MCP-HTTP

MCP: Streamable HTTP transport

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Origin validation, HTTP request behavior, streaming and transport-specific controls. **Limit:** Transport compliance does not establish downstream object authorization or safe tool behavior.

modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http

MCP-TOOLS

MCP: Tools

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Tool input/output schemas, identity, annotations, access controls and implementation responsibilities. **Limit:** Descriptions and annotations are untrusted metadata; they do not enforce read-only behavior or least privilege.

modelcontextprotocol.io/specification/2026-07-28/server/tools

MCP-SAMPLING

MCP: Sampling

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Host control over model sampling requests, tool access and shared context. **Limit:** Sampling permission does not automatically authorize server access to user context or downstream actions.

modelcontextprotocol.io/specification/2026-07-28/client/sampling

MCP-ELICITATION

MCP: Elicitation

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

User information requests, interaction modes, sensitive data and correlated responses. **Limit:** Validate supported modes and version-specific requirements; interaction affordances alone do not prevent phishing.

modelcontextprotocol.io/specification/2026-07-28/client/elicitation

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

MCP-ROOTS**MCP: Roots**

Model Context Protocol maintainers / Protocol specification / 2026-07-28 / 2026-07-28

Client-advertised filesystem roots and scope information supplied to servers. **Limit:** Advertised roots are not an operating-system sandbox; enforce filesystem access independently.

modelcontextprotocol.io/specification/2026-07-28/client/roots

MCP-SECURITY**MCP Security Best Practices**

Model Context Protocol maintainers / Protocol security guidance / 2026-07-28 / 2026-07-28

Confused deputy, token forwarding, discovery SSRF, local launch, URL handling and registration trust. **Limit:** Companion guidance is not a production assurance result. Use this moved documentation path rather than the older specification path.

modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

BENCH-AGENTDOJO**AgentDojo**

ETH Zurich / Invariant Labs / executable research benchmark / NeurIPS 2024; living repository / 2024

Indirect prompt injection and legitimate task utility in tool workflows. **Limit:** Simulated suites and evolving API; adapt to production tools and policies. Not executed here.

github.com/ethz-spylab/agentdojo

BENCH-INJECAGENT**InjecAgent**

UIUC Kang Lab / executable research benchmark / 2024 research; living repository / 2024

Malicious tool-result scenarios for tool-integrated agents. **Limit:** Fixed cases are not an adaptive attacker or production permission test. Not executed here.

github.com/uiuc-kang-lab/InjecAgent

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

BENCH-ASB

Agent Security Bench (ASB)

Agent Security Bench authors / agiresearch / executable research benchmark / ICLR 2025; living repository / 2025

Multiple agent scenarios and attack/defense evaluation methods. **Limit:** Match harness, agent, and tools; published scores do not transfer automatically. Not executed here.

github.com/agiresearch/ASB

BENCH-MCPSECBENCH

MCPSecBench

AIS2Lab / executable research benchmark / 2025 research; living repository / 2025

MCP security playground and attack scenarios across protocol surfaces. **Limit:** Environment/client-specific research workflows; not arbitrary-repository auditing or current-spec conformance. Not executed here.

github.com/AIS2Lab/MCPSecBench

CSA-AICM

AI Controls Matrix v1.1

Cloud Security Alliance / control framework and assessment questionnaire / 1.1 / 2026-06-22

247 control objectives across 18 domains; AI service roles, lifecycle safeguards, and AI-CAIQ supplier assessment. **Limit:** Release page verified; complete workbook not reviewed or reproduced. Engineering alignment only; no exact AICM control mapping or certification claim.

cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1

CSA-AICM-MACHINE

AICM Machine Readable Bundle (JSON/YAML/OSCAL)

Cloud Security Alliance / machine-readable framework distribution / Release page dated 2026-08-04; bundle not imported / 2026-08-04

Publisher-provided machine-readable AICM controls, AI-CAIQ, implementation guidance, and mappings. **Limit:** Landing page verified only. Confirm exact downloadable version and licensing before importing into the scanner.

cloudsecurityalliance.org/artifacts/aicm-machine-readable-bundle-json-yaml-oscal

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

CSA-CCM

Cloud Controls Matrix and CAIQ v4.1

Cloud Security Alliance / cloud control framework and assessment questionnaire / 4.1 / 2026-01-27

207 controls across 17 cloud security domains; infrastructure assurance and provider/customer responsibilities. **Limit:** Release page verified; no exhaustive control-ID mapping. Cloud assessment does not establish security of configured agent behavior.

cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4-1

CSA-MAESTRO

Agentic AI Threat Modeling Framework: MAESTRO

Cloud Security Alliance / threat-modeling framework / Publication dated 2025-02-06 / 2025-02-06

Seven architectural layers and cross-layer attack paths for agentic systems. **Limit:** Analytical framework, not an executable benchmark or normative control catalog.

cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro

CSA-AGENT-IAM

Agentic AI Identity and Access Management: A New Approach

Cloud Security Alliance / architecture guidance / Publication dated 2025-08-18 / 2025-08-18

Agent identity profiles, lifecycle governance, delegation, policy enforcement, and revocation. **Limit:** Proposed architecture; technology choices such as decentralized identifiers are not universal deployment requirements.

cloudsecurityalliance.org/artifacts/agentic-ai-identity-and-access-management-a-new-approach

CSA-SCOPING

Enhancing the Agentic AI Security Scoping Matrix: A Multi-Dimensional Approach

Cloud Security Alliance / risk-scoping guidance / Publication dated 2025-12-16 / 2025-12-16

Access capability and risk exposure across identity, data, logging, agent controls, boundaries, and orchestration. **Limit:** CSA commentary extends an AWS framework. Scoping does not provide measured attack resistance.

cloudsecurityalliance.org/blog/2025/12/16/enhancing-the-agentic-ai-security-scoping-matrix-a-mul...

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

CSA-AISMM

AI Security Maturity Model (AISMM)

Cloud Security Alliance / security program maturity model / Publication dated 2026-05-19 / 2026-05-19

Enterprise AI security program capabilities across self-hosted, PaaS, and API/SaaS deployments. **Limit:** Representative maturity indicators; not a complete checklist or a pass/fail assessment of one AI application.

cloudsecurityalliance.org/artifacts/ai-security-maturity-model

NIST-SSDF-AI

SP 800-218A: Secure Software Development Practices for Generative AI and Dual-Use Foundation Models

NIST / secure-development community profile / SP 800-218A, final / 2024-07-26

AI-specific additions to SSDF 1.1 for model producers, system producers, and acquirers. **Limit:** Use with SP 800-218. Training and model-development controls require applicability decisions for API-only consumers.

csrc.nist.gov/pubs/sp/800/218/a/final

NIST-AGENT-IDENTITY-DRAFT

Accelerating the Adoption of Software and AI Agent Identity and Authorization Concept Paper

NIST National Cybersecurity Center of Excellence / draft concept paper / February 2026 draft / 2026-02-05

Exploration of agent identification, authorization, and accountable access delegation using existing standards. **Limit:** Official page labels it Draft as accessed; not a completed practice guide, mandated standard, or executable benchmark.

www.nccoe.nist.gov/publications/other/accelerating-adoption-software-and-ai-agent-identity-and-a...

MITRE-ATLAS-202609

MITRE ATLAS content release v2026.09

MITRE / threat taxonomy / v2026.09 / 2026-09-15

Versioned AI adversary techniques, mitigations, and case studies for threat modeling and test selection. **Limit:** A threat knowledge base, not a security score or evidence that mapped controls are effective.

github.com/mitre-atlas/atlas-data/releases/tag/v2026.09

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

CIS-CONTROLS-81

CIS Critical Security Controls v8.1

Center for Internet Security / control framework / v8.1 / 2024-06-24

Enterprise security hygiene and implementation-group context for the deployed agent ecosystem. **Limit:** Organizational and deployment evidence required; no full CIS assessment performed.

www.cisecurity.org/controls/v8-1

CIS-AGENTS-2026

Artificial Intelligence (AI) Agents Companion Guide

Center for Internet Security / implementation guidance / v1.0 / CIS Controls v8.1 / 2026-04-20

Agent runtimes, orchestration, tool use, memory, and operational ownership. **Limit:** Official 79-page PDF reviewed; independent checks and partial pointers only. CIS CC BY-NC-ND terms apply to original guide.

www.cisecurity.org/insights/white-papers/controls-v8-1-ai-agents-companion-guide

CIS-MCP-2026

Model Context Protocol (MCP) Companion Guide

Center for Internet Security / implementation guidance / v1.0 / CIS Controls v8.1 / 2026-04-20

Security across MCP hosts, clients, servers, gateways, and connected systems. **Limit:** Official 82-page PDF reviewed; reconcile protocol-era details with deployed MCP. CIS CC BY-NC-ND terms apply to original guide.

www.cisecurity.org/insights/white-papers/controls-v8-1-model-context-protocol-companion-guide

CIS-AI-WORKBOOK

CIS Controls AI Security Guidance Workbook

Center for Internet Security / implementation workbook / Landing page describes workbook v8.1.2 / 2026-07-27

Implementation tracking for LLM, agent, and MCP assets and owners. **Limit:** Public landing page reviewed; workbook cells not audited or imported. Workbook version is not a new overall CIS Controls release.

www.cisecurity.org/insights/white-papers/controls-v8-1-2-ai-security-guidance-workbook

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

CIS-MCP-BENCH-1

CIS MCP Server Benchmark 1.0.0 - official catalog listing

Center for Internet Security / configuration benchmark / MCP Server 1.0.0 / Publication date not stated in reviewed listing

Catalog identifies an MCP server configuration benchmark; select related platform benchmarks for actual deployment. **Limit:** Version/catalog verified only. Official full-benchmark download presents a registration form; full controls not reviewed, reproduced, or implemented.

www.cisecurity.org/cis-benchmarks

OWASP-AISVS-1

Artificial Intelligence Security Verification Standard (AISVS)

OWASP / verification standard / 1.0 / 2026-06

Testable AI security requirements, including agent orchestration and MCP chapters. **Limit:** Selected chapters reviewed; not an exhaustive assessment. General application and infrastructure security must also be verified.

owasp.github.io/www-project-artificial-intelligence-security-verification-standard-aisvs-docs/

OWASP-AISVS-C9

AISVS 1.0 C9 - Orchestration and Agentic Security

OWASP / verification requirements / 1.0, C9 / 2026-06

Agent execution budgets, approval, isolation, identity, delegation, and shutdown. **Limit:** Selected context mappings, not full AISVS conformance. Apply verification levels and preserve version-qualified identifiers.

github.com/OWASP/AISVS/blob/main/1.0/en/0x10-C09-Orchestration-and-Agentic-Action.md

OWASP-AISVS-C10

AISVS 1.0 C10 - Model Context Protocol Security

OWASP / verification requirements / 1.0, C10 / 2026-06

MCP integrity, authorization, transport, schemas, and tool-change review. **Limit:** Application policy may exceed protocol requirements. Legacy initialize/session references require deployed-version interpretation; no full conformity claimed.

github.com/OWASP/AISVS/blob/main/1.0/en/0x10-C10-MCP-Security.md

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

AIUC1-Q3-2026**AIUC-1 Q3 2026 standard update**

Artificial Intelligence Underwriting Company / assurance standard / Q3 2026 / 2026-07-14

Coding-agent controls for credentials, generated-code security, containment, and responsibility boundaries. **Limit:** Privately maintained assurance program. Scanner output is not certification or completion of independent evaluation.

www.aiuc-1.com/research/2026-q3-standard-update

ISO-42001-2023**ISO/IEC 42001:2023 - AI management systems**

ISO/IEC / management system standard / Edition 1 / 2023-12

Public description of an organizational AI management system. **Limit:** Public description only; proprietary standard text not reproduced and no clause-level compliance mapping.

www.iso.org/standard/42001

ISO-23894-2023**ISO/IEC 23894:2023 - AI guidance on risk management**

ISO/IEC / risk management guidance / Edition 1 / 2023-02

Public description of integrating AI risk management into organizational activities. **Limit:** Public abstract only; proprietary clauses not reviewed or mapped.

www.iso.org/standard/77304.html

OPENSSEF-BASELINE-202608**Open Source Project Security Baseline**

OpenSSF / project security baseline / v2026.08.28 / 2026-08-28

Project-maturity baseline for source, builds, releases, documentation, and vulnerability handling. **Limit:** General project security, not agent behavior or deployed authorization assurance.

baseline.openssf.org/versions/2026-08-28

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

SLSA-12

Supply-chain Levels for Software Artifacts specification

SLSA / OpenSSF / supply chain specification / 1.2, approved / Release date not stated on reviewed specification page

Source and build integrity, provenance, attestations, and verification. **Limit:** Artifact origin and build integrity do not establish safe agent behavior or absence of vulnerabilities.

slsa.dev/spec/v1.2/

OPENSSEF-SCORECARD

OpenSSF Scorecard

OpenSSF / repository assessment tool / Living project / Living source; reviewed 2026-09-19

Automated repository and dependency security signals. **Limit:** Heuristic scores do not certify security; not executed for this publication.

securityscorecards.dev/

OPENSSEF-MODEL-SIGNING

Launch of Model Signing v1.0

OpenSSF / artifact integrity tooling / v1.0 launch reference / 2025-04-04

Signing and verifying model-artifact origin and integrity. **Limit:** A signature is not evidence that a model is free from backdoors, unsafe behavior, or licensing concerns.

[openssf.org/blog/2025/04/04/launch-of-model-signing-v1-0-openssf-ai-ml-working-group-secures-the...](https://openssf.org/blog/2025/04/04/launch-of-model-signing-v1-0-openssf-ai-ml-working-group-secures-the-...)

BENCH-MSB

MCP Security Bench (MSB)

Dongsen Zhang and coauthors / executable research benchmark / Paper v2; ICLR 2026; living repository / 2026-03-24

Real MCP tool attacks across planning, invocation, and response handling with a security/utility trade-off metric. **Limit:** Distinct from MCPSecBench; selected tools, domains, agents, and code revisions bound results. Not executed here.

github.com/dongsenzhang/MSB

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

BENCH-MCP-SAFETY

MCP-SafetyBench

Xuanjun Zong and coauthors / executable research benchmark / Paper v2; living repository / 2026-03-05

Multi-turn, cross-server safety evaluation using real MCP servers in five domains and 20 attack types. **Limit:** Service state, harness assumptions, and task selection affect reproducibility; not protocol authorization certification. Not executed here.

github.com/xjzzzzzzzz/MCPSafety

BENCH-AGENTDYN

AgentDyn

SaFo-Lab / Hao Li and coauthors / executable research benchmark / Paper v3; living repository / 2026-05-07

Dynamic open-ended tasks and helpful third-party instructions expose over-blocking by injection defenses. **Limit:** Extends AgentDojo and inherits harness assumptions; avoid double-counting identical scenarios. Not executed here.

github.com/SaFo-Lab/AgentDyn

BENCH-AGENTHARM

AgentHarm

Gray Swan AI / UK AI Safety Institute and coauthors / executable research benchmark / ICLR 2025; living Inspect Evals implementation / 2025

Harmful multi-step user requests and jailbreaks with corresponding benign tasks. **Limit:** Different threat model from indirect injection. Grading can use LLMs; public subsets, scoring revisions, and safety/security-use license apply. Not executed here.

github.com/UKGovernmentBEIS/inspect_evals/blob/main/src/inspect_evals/agentharm/README.md

BENCH-BIPIA

BIPIA

Microsoft / Jingwei Yi and coauthors / executable research benchmark / 2023 initial paper; living repository / 2023

Indirect prompt injection in external email, web, table, summarization, and code content. **Limit:** External-content robustness, not full agent/MCP transport security; some datasets require separate licensed acquisition. Not executed here.

github.com/microsoft/BIPIA

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

TECH-GITHUB-ACTIONS

GitHub Actions: Secure use reference

GitHub / Vendor security documentation / Living GitHub Actions documentation / Living documentation

Third-party workflow action integrity, full commit pinning, workflow permissions, secrets and untrusted input handling. **Limit:** The older cited URL redirects to the current Secure use reference. Pinning mitigates mutable-action changes but does not prove the pinned action is safe.

docs.github.com/en/actions/security-for-github-actions/security-guides/security-hardening-for-gi...

TECH-PYTHON-SECURITY

Python Security Considerations

Python Software Foundation / Language security documentation / Python 3.14.7 documentation at review / Living documentation

Security-sensitive standard-library APIs, including serialization, subprocesses, temporary files and related trust boundaries. **Limit:** The /3 URL tracks current Python documentation. Check the installed runtime and follow linked module-specific guidance; this overview is not an agent/MCP security standard.

docs.python.org/3/library/security_warnings.html

TECH-PYTHON-TAR

Python tarfile: Extraction filters

Python Software Foundation / Language security documentation / Python 3.14.7 documentation at review / Living documentation

Extraction filters, path and link restrictions, trusted archives and additional resource controls. **Limit:** Default extraction behavior differs by Python version and security backports. A data filter does not prevent every denial-of-service or unsafe-file outcome; inspect inputs and constrain resource use.

docs.python.org/3/library/tarfile.html#extraction-filters

TECH-NODE-PROCESS

Node.js Child process

Node.js contributors / Runtime API documentation / Node.js v26.9.0 documentation at review / Living documentation

Shell interpretation and process-spawning behavior, including risks from untrusted input passed to exec or shell-enabled spawn. **Limit:** The URL follows current Node documentation; platform and runtime versions matter. Static shell-call detection does not establish attacker-controlled data flow.

nodejs.org/api/child_process.html

07 / SOURCE DIRECTORY

Follow the evidence

Primary-source links and version context. Accessed 19 September 2026 unless the entry states otherwise.

TECH-PYTORCH-SERIAL

PyTorch Serialization semantics

PyTorch contributors / Framework security documentation / PyTorch 2.14 documentation at review / Living documentation

Checkpoint trust, torch.load, restricted weights-only loading and serialization security limits. **Limit:** The old domain redirects to docs.pytorch.org and its stable page resolves to 2.14. Defaults vary by PyTorch version; restricted loading is not a universal defense against malicious artifacts.

pytorch.org/docs/stable/notes/serialization.html

TECH-PYYAML

PyYAML Documentation

PyYAML maintainers / Library documentation / Living documentation; includes historical examples / Living documentation

YAML object construction, SafeLoader and safe_load behavior when processing untrusted documents. **Limit:** Examples span historical PyYAML versions; assess the installed loader and registered constructors. Safe loading still needs application schemas, input limits and resource controls.

pyyaml.org/wiki/PyYAMLDocumentation

CISA-SECURE-BY-DESIGN

Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Secure by Design Software

CISA and U.S./international partners / Government secure-development guidance / October 2023 update / 2023-10-25

Manufacturer responsibility for security outcomes, accountable development and secure product defaults. **Limit:** General engineering rationale for several scanner rules. The publication does not define these individual source patterns, severity ratings or a pass/fail agent security benchmark.

www.cisa.gov/resources-tools/resources/secure-by-design
